GDPR · CUSTOMER DATA · CYBERSECURITY

THE PRIVACY-SAFE ONLINE *Shop*

GDPR, Customer Data and Cybersecurity for E-commerce Owners



PLUS **7** Ready-to-use Templates

CUSTOMER ACCOUNTS

MARKETING DATABASES

PAYMENT PROVIDERS

RETURNS & CUSTOMER INFO

30-DAY PLAN · CHECKLISTS · BREACH PLAYBOOK

ZIRLANDIA MILKOVIC



THE PRIVACY-SAFE

ONLINE *Shop*

FOR E-COMMERCE OWNERS

GDPR, Customer Data and Cybersecurity for E-commerce Owners

ZIRLANDIA MILKOVIC

FOR E-COMMERCE OWNERS · GDPR · CYBERSECURITY

The Privacy-Safe Online Shop

GDPR, Customer Data and Cybersecurity for E-commerce Owners

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced, stored or transmitted in any form without written permission, except for brief quotations in reviews and for printing the worksheets, checklists and the notice templates for your own business use.

NOT LEGAL ADVICE. This book is an educational guide to the EU General Data Protection Regulation (Regulation (EU) 2016/679). It is not legal advice, does not create a lawyer-client or consultant-client relationship, and does not take your individual circumstances into account. Reading it, following it or using its templates does not make a business GDPR compliant and is not a certification or a guarantee of compliance.

LAWS CHANGE. Data protection law, regulatory guidance, court decisions and national rules develop continuously. The book reflects the author's understanding as of its publication date (2026) and refers to official sources so that you can check what applies now. National laws, supervisory-authority guidance and sector rules differ between countries. Before you rely on anything here for a decision with real consequences, take advice from a qualified lawyer or data protection professional in the relevant country.

Product and company names (for example email, analytics, advertising and AI platforms) are the property of their respective owners and are used only as examples for identification and education. This independent book is not affiliated with, sponsored by or endorsed by any of them, and no product is recommended or certified as compliant.

Every person, business and incident described in the case studies and scenarios is fictional and was created to illustrate ideas. Any resemblance to real people or companies is coincidental.

Premium Edition 2026 · PDF with clickable contents, bookmarks and fillable worksheets

Contents

Note	A Note from the Author	5
01	Your Shop Is a Data Business	6
02	Map Your Customer Data	10
03	Customer Accounts and Checkout	14
04	Marketing Databases and Consent	18
05	Cookies, Analytics and Ad Pixels	22
06	Payment Providers	26
07	Suppliers, Couriers and Third Parties	30
08	Returns and Customer Information	34
09	The Shop Security Baseline	38
10	How Online Shops Get Attacked	42
11	If Something Goes Wrong	46
12	Rights, Retention and Documents	51
13	Your 30-Day Privacy-Safe Shop Plan	55
Bonus	Privacy-Safe Shop Toolkit	59
A–Z	Plain-English Glossary	65
Ref	Official Sources & Further Reading	66
Bio	About the Author	68

A Note from the Author

Why a small online shop is a data business, and why privacy is the cheapest security you will ever buy.

When you opened your shop, you probably thought you were selling products. You were, but you also started collecting names, addresses, phone numbers, order histories, payment details, delivery instructions, returns photos and the emails of everyone who ever signed up for ten per cent off. Every one of those records is personal data, and every one of them is now your responsibility.

That responsibility is not a burden reserved for large retailers. The GDPR applies to a shop with three customers a week in exactly the same way it applies to a marketplace with three million. What differs is the size of the machinery you need. A small shop does not need a compliance department. It needs a short list of good habits: collect less, keep it for less time, share it with fewer parties, and protect what remains.

Customers do not remember that a shop followed the rules. They remember the one time it did not. A leaked customer list, a marketing email to someone who unsubscribed, a return form that asked for far too much: these are the moments that cost sales, reviews and, occasionally, a fine.

This book follows the customer's journey through your shop: the account they create, the marketing list they join, the payment they make, the parcel that leaves your door and the return that sometimes comes back. At each step it explains what the law expects, what attackers target and what a sensible small shop can do about both. At the back is a toolkit of ready-to-fill sheets.

AI & PRIVACY **How to use this book**

If you are in a hurry, read Chapter 1 and the Chapter 13 plan, then work through the Bonus toolkit. **If you have a weekend**, read it in order. **If you have just had a problem**, go to Chapter 11. Each chapter ends with a short action list so that reading turns into doing.

PART I · THE SHOP AND ITS DATA

CHAPTER

01

Your Shop Is a Data Business

What personal data an online shop really holds, who is responsible for it, and the seven rules that shape everything else.

IN THIS CHAPTER

- Why every online shop is a data business
- What counts as personal data in e-commerce
- Controller, processor and joint controller, in shop terms
- The seven GDPR principles applied to a webshop

Clara sells hand-poured candles from a spare room. She has no employees, a simple shop on a hosted platform and about forty orders a week. When a friend asks whether she needs to worry about the GDPR, she laughs: "I only sell candles." Then she opens her admin panel and counts what is in it: 6,800 customer records, a newsletter list, order notes saying "leave with the neighbour at number 4", a returns inbox full of photos, a spreadsheet of wholesale contacts and a support chat with three years of history.

Clara does not sell candles. Clara runs a small data business that happens to sell candles.

What personal data does a shop hold?

Personal data is any information relating to an identifiable person (Art. 4(1) GDPR). In e-commerce that is far wider than most owners expect, because the data is not only what customers type in. It is also what your systems collect about them.



Figure 1 Four layers of shop data

> **GDPR IN PLAIN ENGLISH** **Data you may not think of as personal**
>
> An order number alone looks harmless, but linked to a name it is personal data. So is an IP address, a device ID, a delivery note that mentions a neighbour and a photo of a damaged parcel with a visible address label. If you can single out a person using it, or combine it with other data you hold, it counts.

Who is responsible for what?

The GDPR uses three roles that matter to every shop owner.

01
CONTROLLER

The one who decides why and how personal data is used. For your customers' data, that is you. You answer to customers and to the authority.

02
PROCESSOR

A supplier that handles data on your instructions: your shop platform, email service, courier portal, helpdesk, accountant. You need a written contract (Art. 28).

03
JOINT CONTROLLER

Two parties that decide purposes and means together, for example when you place an advertising pixel and the ad platform also uses the data for its own purposes.

Figure 2 Your three roles

Some suppliers wear two hats. A payment provider processes payments for you but is usually an independent controller for its own fraud checks and legal duties. A courier is often an independent controller for delivery data. Chapters 6 and 7 explain how to tell the difference without a law degree.

The seven principles, in shop language

Article 5 sets out the principles behind every other rule. You do not need to memorise legal wording, but you do need to be able to say what each means for your shop.

The principles of Article 5 as a shop owner

Principle	What it means in your shop
Lawfulness, fairness, transparency	You have a valid reason for each use, you do nothing customers would find sneaky, and your privacy notice says clearly what you do.
Purpose limitation	Delivery addresses are for delivery. They are not automatically for a postcard campaign.
Data minimisation	Ask only for what you need. A candle does not need a date of birth.
Accuracy	Customers can correct their details and you fix mistakes.
Storage limitation	Delete or anonymise data when you no longer need it. Old carts and unconfirmed sign-ups go first.
Integrity and confidentiality	Protect data against loss, theft and misuse (Art. 32).
Accountability	You can show what you do: records, contracts, decisions written down.

GOOD PRACTICE **The shortcut**

Whenever you add a form field, a tool or a campaign, ask three questions. **Why do I need this? Who else sees it? When will I delete it?** If you cannot answer all three, wait.

Why e-commerce attracts attention

Online shops combine three things that regulators and criminals both like: large volumes of personal data, a public-facing website that is easy to probe, and payment information. Authorities have also made online retail a recurring enforcement target, especially around cookies and marketing. In September 2025 the French authority CNIL fined the company behind Shein EUR 150 million for placing advertising cookies without proper consent, a reminder that a shop's website itself can be the source of the problem.

You will probably never face a fine of that size. The point is that the same weaknesses scale down: a banner that does not really let customers refuse, a pixel that fires before consent, a supplier with no contract. The rest of this book fixes them one by one.

> **DO THIS NOW** **Do this today**
>
> Open your shop admin and write down every place customer data lives: platform, email tool, helpdesk, spreadsheets, accounting, courier portals. Do not worry about completeness. This list is the start of the data map in Chapter 2.

PART I · THE SHOP AND ITS DATA

CHAPTER

02

Map Your Customer Data

A one-hour exercise that shows where data enters, where it travels and where it should be deleted.

IN THIS CHAPTER

- How to draw a simple data map for your shop
- The lawful bases a shop actually uses
- What to write in a record of processing
- The questions that expose hidden risks

You cannot protect what you cannot find. Every other chapter of this book depends on knowing, in one place, what you collect, why, where it goes and how long you keep it. That one page is called a data map, and for a small shop it takes about an hour.

Follow the customer

The easiest way to build the map is to walk through the customer's journey and note every moment a system sees personal data.

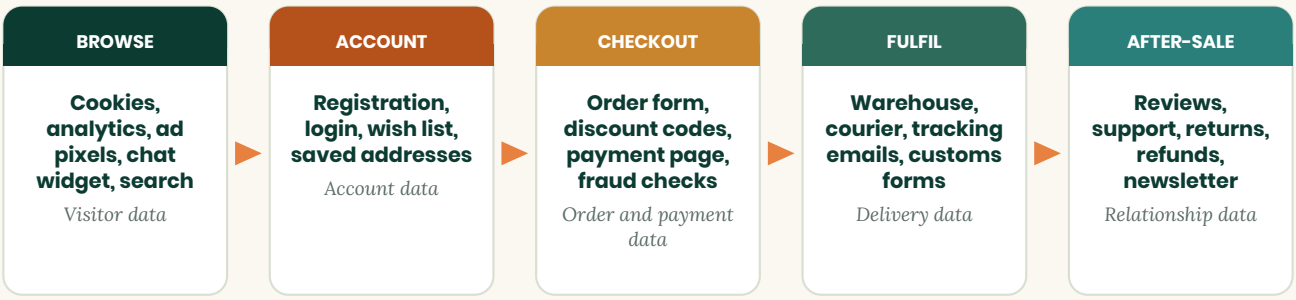


Figure 3 From click to doorstep

For each stage, ask which tools are involved and who owns them. A shop on a hosted platform often finds that a dozen or more outside services touch customer data: the platform itself, a theme, several apps, analytics, advertising, email, reviews, a loyalty plugin, the payment provider, the courier, the accountant and the helpdesk.

Build the one-page map

Data map: one row per purpose

Purpose	Data	Source	Shared with	Keep for
Fulfil an order	Name, address, items, phone	Customer at checkout	Platform, courier	Until delivered, then invoice only
Take payment	Payment status, billing name	Payment page	Payment provider	Per tax law
Newsletter	Email, consent record	Sign-up form	Email tool	Until unsubscribe
Customer support	Messages, order number	Email, chat	Helpdesk	12 months after closing
Fraud prevention	IP, device, order pattern	Shop and provider	Fraud tool	6 months unless case open

FOUNDER TIP **Use the sheet at the back**

The Bonus toolkit includes a data map sheet and a supplier register. Fill them in on screen and update them whenever you add a tool.

Pick a lawful basis for each purpose

Every use of personal data needs one of the six lawful bases in Article 6. Shops use four of them over and over.

01
CONTRACT (6(1)(b))

The customer ordered something and you need their data to deliver it, take payment and handle returns. No consent needed.

02
LEGAL OBLIGATION (6(1)(c))

You must keep invoices and accounting records for the period set by national tax law, and answer some official requests.

03
LEGITIMATE INTERESTS (6(1)(f))

A balanced interest such as basic fraud prevention, network security or, where allowed, marketing to existing customers. Document a short balancing test.

04
CONSENT (6(1)(a))

Free, specific, informed, unambiguous and withdrawable. Needed for most advertising cookies, many newsletters and anything optional.

Figure 4 The four bases a shop actually uses

WATCH OUT **Do not use consent for everything**

Asking for consent when you actually rely on a contract is a classic mistake. If a customer withdraws consent for something you really need to deliver the order, you are stuck. Use consent only for genuinely optional extras, and make refusing as easy as agreeing.

Your record of processing

Article 30 requires a written record of processing activities. The small-business exemption in Article 30(5) is narrow and rarely helps a shop that regularly processes customer data, so assume you need one. The data map above, with a few extra columns for recipients, transfers outside the EEA and security measures, is a perfectly good record.

Questions that expose the risk

- Which tools collect data that I never asked for? Plugins and themes are common culprits.
- Which suppliers do I have no contract with?
- Where is customer data copied outside the shop: exports, spreadsheets, laptops, shared drives?
- Which data have I kept for years "just in case"?
- Does any data leave the EEA, for example to a US-based tool?
- Who in my team can see everything, and do they need to?

DO THIS NOW **Action list**

Draw your journey chain. Fill in one row per purpose. Mark every row where the "keep for" column says "forever" or "don't know". Those are your first fixes.

PART II · CUSTOMERS AND THEIR ACCOUNTS

CHAPTER

03

Customer Accounts and Checkout

Guest checkout, account sign-up, passwords and deletion: collecting what you need and nothing more.

IN THIS CHAPTER

- Why guest checkout is the privacy-friendly default
- What to ask for at sign-up and checkout
- How to protect customer logins
- How to handle account deletion and children

Every extra field on a checkout form costs you twice. It lowers conversions, and it adds to the pile of data you must protect, explain and eventually delete. The privacy-safe checkout is also the faster one.

Offer guest checkout

Forcing customers to create an account just to buy once is hard to justify. For a one-off order, you need only the data required to deliver and invoice it. An account is a separate service that customers may choose. Offer guest checkout, and offer an account afterwards as an option, with a clear explanation of what it does.

GUEST CHECKOUT

- Only the data needed for this order.
- Basis: contract, and legal obligation for the invoice.
- Nothing to secure beyond the order record.
- No password to be stolen.

CUSTOMER ACCOUNT

- Saved addresses, order history, wish lists, preferences.
- Basis: contract for the account service you offer.
- Needs a login, passwords and a way to delete the account.
- A target for credential stuffing and takeover.

Figure 5 Account versus guest checkout

The minimum form

What a checkout form needs, field by field

Field	Needed?	Comment
Name and delivery address	Yes	Needed to deliver the goods.
Email address	Yes	Order confirmation and delivery updates.
Phone number	Usually optional	Mark it optional unless the courier truly requires it. Explain why.
Date of birth	Only for age-restricted goods	Check age at the point of sale; do not store the date.
Gender or title	No	Rarely needed, often collected out of habit.
Company VAT number	Only for business customers	Needed for the invoice in that case.
Newsletter tick box	Optional	Never pre-ticked, never bundled with the order terms.

WATCH OUT **Pre-ticked boxes are not consent**

The Court of Justice of the EU held in the Planet49 case (C-673/17, 2019) that a pre-ticked box cannot give valid consent. The same logic applies to marketing tick boxes at checkout. An unticked box that the customer must actively tick is the only safe design.

Protect the login

If you offer accounts, you are responsible for the security of the login (Art. 32). Attackers do not hack accounts one by one. They take lists of email and password pairs leaked from other websites and try them against your shop automatically. This is called credential stuffing, and it works because many people reuse passwords.

ACCOUNT SECURITY FOR A SHOP

- [ ] Passwords are stored hashed by your platform, never in plain text or readable form. Check that your platform does this.
- [ ] Customers can sign in with a one-time email link or passkey, or turn on two-step verification.
- [ ] Failed login attempts are limited and unusual patterns trigger a block or a challenge.

- [ ] Customers are told when their password or email address is changed, and when a login happens from a new device.
- [ ] Saved payment details are held by the payment provider as tokens, not by you.
- [ ] Admin accounts are separate from customer accounts and always use two-step verification.

Let customers leave

Customers have the right to ask you to delete their account (Art. 17), and you should make it simple: a visible button or a clear email address, not a hunt through the footer. When an account is deleted you remove the profile, saved addresses, wish lists and marketing preferences. You may keep what the law requires you to keep, usually the invoice and order records for tax purposes, in a restricted form and only for the legal period.

> **GDPR IN PLAIN ENGLISH** **Deleting is not all or nothing**
>
> Chapter 12 explains how to delete an account while keeping the invoice. A customer who asks for erasure is not asking you to break tax law, and you do not have to. You do have to tell them what you keep and why.

Children and age

If your shop sells to or is attractive to children, extra care applies. Where you rely on consent to offer an online service directly to a child, Article 8 sets the age at which the child can consent alone between 13 and 16 depending on the country. Many shops avoid the issue by stating that accounts and marketing are for adults only, and by not profiling minors.

Fraud checks at checkout

Many shops run order screening to stop stolen cards. That is a legitimate interest, but keep it proportionate. Do not collect ID documents for ordinary orders. Be careful with tools that automatically refuse a customer based on a score: a fully automated decision with significant effect can trigger Article 22. In 2023 the Court of Justice (SCHUFA, C-634/21) treated the production of a credit score as an automated decision when a lender relies on it heavily. If a tool can say no on its own, keep a way for a person to review the outcome.

> **DO THIS NOW** **Action list**
>
> Remove every checkout field you cannot justify. Switch guest checkout on. Untick every marketing box. Turn on two-step verification for all admin users. Add a visible way to delete an account.



PART II · CUSTOMERS AND THEIR ACCOUNTS

CHAPTER

04

Marketing Databases and Consent

Newsletters, abandoned carts, imported lists and segments: how to build a list that is both lawful and profitable.

IN THIS CHAPTER

- When you may email customers, and when you need consent
- How to record and prove consent
- How to run unsubscribes, suppression lists and segments
- What to do with an old or bought list

A marketing list is the most valuable data a small shop owns, and the data most likely to cause a complaint. Two laws apply to it together: the GDPR, which governs how you hold and use the data, and the ePrivacy rules, which govern whether you may send the message at all.

Two sets of rules

The ePrivacy Directive (2002/58/EC), implemented in each country's law, says that electronic marketing by email or text normally needs prior consent. Article 13(2) contains a narrow exception, often called the soft opt-in, which many countries have adopted.

01
CONSENT

The customer ticked an unticked box or otherwise clearly agreed, knowing what they would get. You can prove when and how. This is the safest route for all subscribers.

02
EXISTING CUSTOMERS (SOFT OPT-IN)

You obtained the email address during a sale, you market only your own similar products, and the customer could refuse easily at collection and in every message. National rules vary, so check yours.

03
BUSINESS CONTACTS

Rules differ by country for company addresses. Do not assume that a business email can be mailed without checks.

04
BOUGHT OR SCRAPED LISTS

Almost never acceptable. You cannot show that these people consented to hear from you.

Figure 6 When you may send marketing emails

WATCH OUT **The right to object is absolute for marketing**

Under Article 21(2) and (3), a person can object to direct marketing at any time and you must stop. There is no balancing test and no reason needs to be given. Add the person to a suppression list so they are not re-imported next month.

Record consent properly

If you rely on consent, Article 7(1) requires you to be able to demonstrate it. A subscriber row with just an email address is not evidence.

What to store for each subscriber

Field	Example
Email address	name@example.com
Date and time of consent	14 Mar 2026, 10:42 UTC
Source	Footer sign-up form, version 3
Wording shown at the time	"Send me news and offers from Clara's Candles"
Method	Unticked box, double opt-in confirmed
Withdrawal	Date and channel, or blank

Double opt-in, meaning a confirmation link sent to the address, is not mandatory everywhere, but it is the best proof and it keeps your list free of mistyped and malicious sign-ups.

Abandoned-cart emails

Reminding someone about the basket they left is a common tactic. Whether it needs consent depends on the country and the method. In many places a reminder to a logged-in customer sent only once is accepted as part of the service, while a sequence of promotional messages is marketing and needs a basis. If the reminder is triggered by a tracking cookie, the cookie rules in Chapter 5 apply as well. The safe route is to ask the customer at the point they enter their email, with a short and honest explanation.

Segments and profiles

Splitting a list by what people bought is normal. Building detailed profiles of behaviour, inferred income, estimated pregnancy or health interests is another matter, and may need a stronger basis or a data protection impact assessment (Chapter 12). Keep segments simple and explainable. If you could not tell a customer in one sentence why they received a message, rethink the segment.

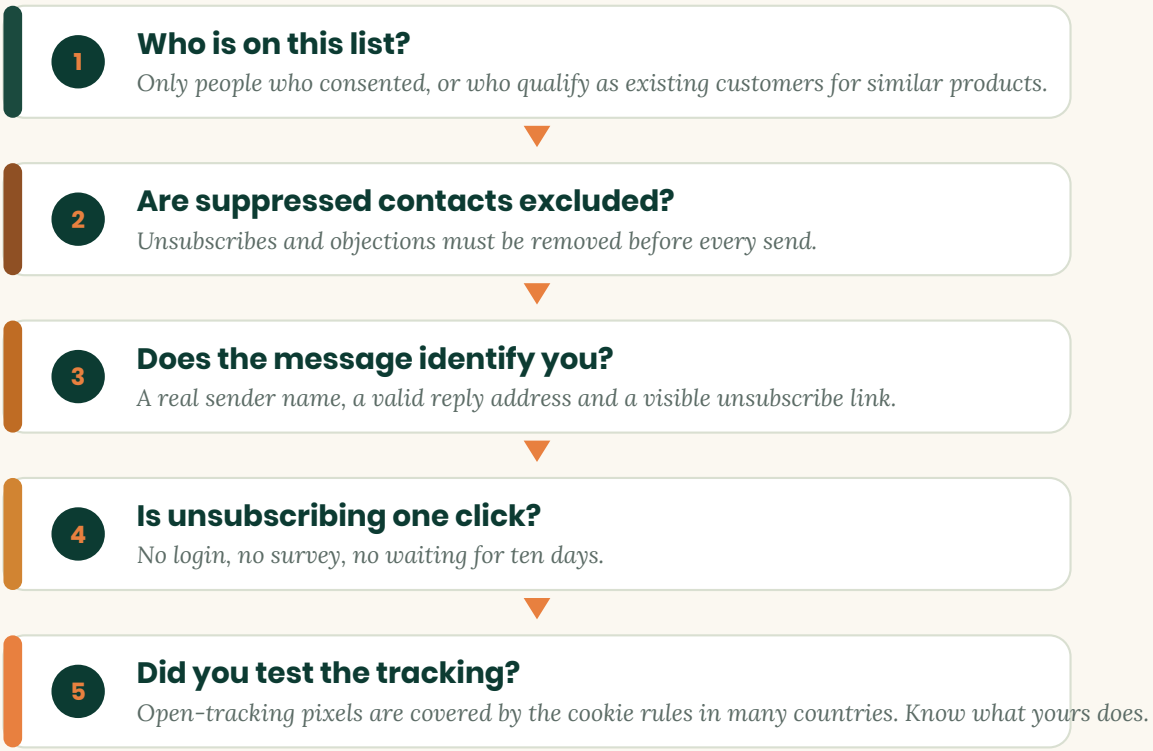


Figure 7 Before every campaign

Old lists, bought lists and imports

The most common marketing problem is not a new mistake but an old one. The list started in 2018 from a prize draw, was merged with a trade-show spreadsheet and then imported into a new tool. Nobody can say where anyone came from. The honest fix is a re-permission campaign to the people you can reasonably justify mailing, followed by deleting the rest. A smaller list that wants your emails performs better than a larger list that does not.

REAL-WORLD SCENARIO **Real-world scenario: the imported spreadsheet**

A small fashion shop imports 9,000 contacts from an old market-stall mailing list into a new email tool and sends a launch campaign. Forty people complain to the authority that they never gave their email. The shop cannot show consent for any of them. The regulator accepts the shop's quick deletion of the list and cooperation, and issues a reprimand rather than a fine. The campaign revenue is lost, and so are the weeks spent answering complaints.

DO THIS NOW **Action list**

Export your list with source and date. Delete anyone with no provable source. Add an unticked sign-up box with clear wording. Switch on double opt-in. Test your unsubscribe link today and make sure it works in one click.

PART II · CUSTOMERS AND THEIR ACCOUNTS

CHAPTER

05

Cookies, Analytics and Ad Pixels

What the law says about trackers on your shop, and how to run a banner that is honest and still lets you measure.

IN THIS CHAPTER

- Which trackers need consent and which do not
- How to run a consent banner that holds up
- What ad pixels and analytics tools really send
- Safer ways to measure your shop

Most online shops load far more third-party code than their owners realise. A theme, a review widget, a chat bubble, an analytics tag and three advertising pixels can each set cookies and send data about visitors to a different company. Under the ePrivacy rules and the GDPR, you are responsible for all of it.

Two laws at work

Article 5(3) of the ePrivacy Directive requires consent before storing or reading information on a visitor's device, with an exception for what is strictly necessary to deliver a service the visitor asked for. The GDPR then applies to any personal data you process using those trackers. Together they produce a simple rule: **necessary cookies need no consent, everything else does.**

Cookie categories in a shop

Category	Examples	Consent needed?
Strictly necessary	Basket, session, login, load balancing, payment security	No
Preferences	Language or currency memory beyond the session	Usually yes
Analytics	Visit counts, page paths, funnel steps	Yes in most countries, unless it is narrowly limited and your authority exempts it
Advertising and retargeting	Pixels from ad networks and social media	Yes, before anything fires
Embedded content	Video players and maps from third parties	Yes, before loading

GDPR IN PLAIN ENGLISH **What the courts and regulators have said**

In Planet49 (C-673/17, 2019) the EU Court ruled that consent for cookies must be active, and pre-ticked boxes do not count. In Fashion ID (C-40/17, 2019) it held that a website embedding a social media button can be a joint controller with the platform for the data collected. Authorities across the EU, including CNIL, have enforced the principle that refusing cookies must be as easy as accepting them.

A banner that holds up

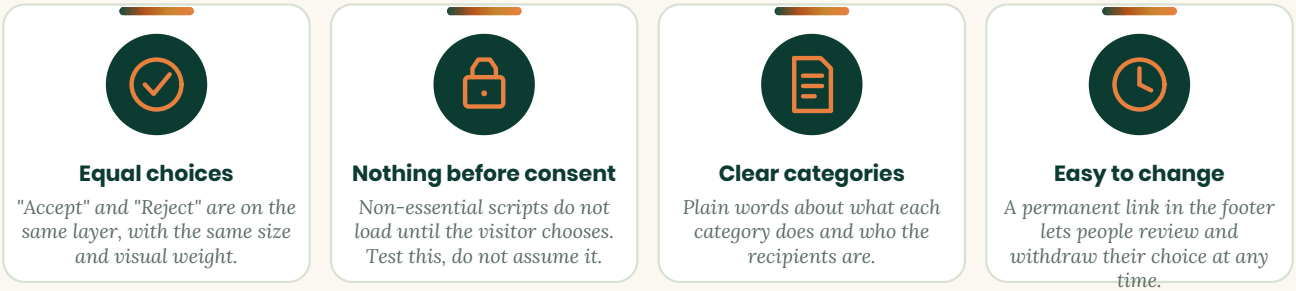


Figure 8 Four marks of a trustworthy consent banner

WATCH OUT **Test what actually fires**

Open your shop in a private window, decline all cookies, and check the browser developer tools or a free scanner. Many shops have a perfect-looking banner and still load the advertising pixel on the first page view because the tag was hard-coded into the theme. That is exactly the failure regulators check for.

What pixels and analytics send

An advertising pixel sends the ad platform your visitor's identifiers, the pages they view, the products they add to the basket and often a hashed email or phone number at purchase. That is personal data about shoppers. The platform uses it to match visitors with their own accounts and, usually, for its own purposes. This is why the pixel is where joint controllership and international transfers meet.

- **Check each tag.** If you cannot explain why it exists, remove it. Old agency tags are common.
- **Limit what is sent.** Turn off automatic advanced matching, and do not pass email addresses or order notes into tags.
- **Look at the data location.** Many analytics and advertising tools are operated by US companies. Transfers rely on the EU-US Data Privacy Framework (adequacy decision of 10 July 2023) or other safeguards, and the framework has faced legal challenges. Check its current status.
- **Review annually.** Tags creep. A yearly audit removes the forgotten ones.

Measure with less

You do not have to give up measurement. You can reduce how much you collect: use privacy-focused analytics with no cross-site identifiers, aggregate data rather than individual journeys, shorten retention and consider server-side tracking that you control. Some national authorities treat certain narrowly configured analytics as exempt from consent, but the rule varies, so check yours before relying on it.

FOUNDER TIP **Honest numbers**

Banners that give a real choice reduce the share of tracked visitors, so your reported conversion rate may look worse. Your actual sales do not change. Use order data from the shop itself, not only advertising dashboards, to judge performance.

DO THIS NOW **Action list**

Run a cookie scan in a private window with everything declined. List every tag and delete the unexplained ones. Make Reject as visible as Accept. Add a footer link to change cookie settings. Review all tags again in twelve months.

PART III · PAYMENTS, FULFILMENT AND RETURNS

CHAPTER

06

Payment Providers

What you should never store, who is responsible for what, and how to keep card data off your systems altogether.

IN THIS CHAPTER

- Why the safest card data is data you never touch
- The roles of you and your payment provider
- What PCI DSS and strong customer authentication mean for you
- How card skimming attacks reach checkout pages

Payment data is the part of your shop that feels most dangerous, and for good reason. Yet for a small shop it can also be the easiest part to get right, because the best protection is to arrange things so card numbers never reach your systems at all.

The golden rule: do not handle card numbers

Modern payment providers offer hosted payment pages, redirects and embedded fields served from the provider's own servers. The customer types the card number into the provider's form, not yours. Your shop receives only a token, a payment status and perhaps the last four digits. A breach of your shop then cannot leak card numbers, because you never had them.

YOU HANDLE THE CARD

- The card number passes through your server or page code.
- Your whole shop is in scope for the strictest PCI DSS requirements.
- A breach of your site exposes card numbers.
- Extra audits, logs, and responsibility.

PROVIDER HANDLES THE CARD

- The customer types the number into the provider's hosted fields or page.
- You receive a token and a payment status.
- A breach of your site does not expose card numbers.
- Far lighter compliance duties.

Figure 9 Where the card number goes

WHAT GDPR REQUIRES **Never store these**

The card security code (CVV or CVC) must not be stored after a payment is authorised, even if encrypted. Full card numbers should not be stored by a small shop at all, and never in emails, order notes, spreadsheets, chat messages or call recordings. If a customer sends card details in an email, do not process them that way: delete the message, and ask the customer to use the payment link.

Who is the controller?

Your payment provider processes the payment for you, so for that purpose it acts on your behalf, under the provider's terms and data processing agreement. It is also usually a separate controller for its own legal duties such as anti-money-laundering checks and fraud prevention. Read the provider's data protection terms and note the role split in your records. You are still responsible for telling customers, in your privacy notice, that payments are handled by the provider.

PCI DSS in plain words

The Payment Card Industry Data Security Standard is a contractual standard set by the card brands, not a law, and your bank or provider will ask you to confirm compliance. Which questionnaire you complete depends on how you take payments. Shops that use fully hosted payment pages usually fill in the shortest one. The current version is 4.0.1, and its requirements for managing and monitoring the scripts on payment pages became mandatory from 31 March 2025. In practice: know every script that runs on your payment page, and keep it to the minimum.

Strong customer authentication

Under the Payment Services Directive (PSD2), most online card payments in the European Economic Area require two-factor authentication of the customer, commonly through 3-D Secure. Your provider normally configures this for you. For privacy, it means the extra data your provider collects at checkout, such as device information, is for fraud prevention and authentication, and should be covered in your notice.

How card skimming reaches checkout

The most damaging e-commerce attacks do not break into databases. They insert a few lines of malicious script into a checkout page, which copy what customers type and send it to criminals. Security teams call this Magecart-style skimming. It often arrives through a third-party script, a vulnerable plugin or a compromised theme.

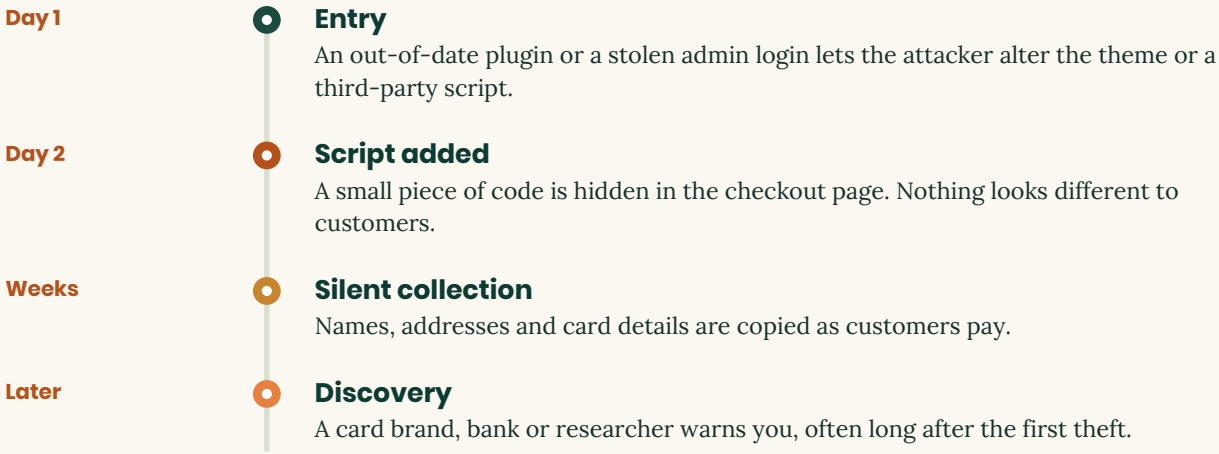


Figure 10 How a skimming attack unfolds

REAL-WORLD SCENARIO **Real-world lessons from regulators**

In 2020 the UK Information Commissioner fined British Airways GBP 20 million after attackers diverted customer details from its website payment page, and fined Ticketmaster UK GBP 1.25 million because a third-party chatbot on its payment page was compromised and the company had not adequately secured or checked it. Ticketmaster could not shift the responsibility to its supplier: the regulator held it accountable for the script it chose to run. The lesson fits any shop: **every script on a payment page is your responsibility.**

Protect the payment page

PAYMENT PAGE HYGIENE

- [ ] Card details are entered only in provider-hosted fields or pages, never in your own form.
- [ ] Every script on the checkout page is listed, necessary and from a source you trust. Marketing tags are removed from checkout.
- [ ] Plugins, themes and the platform itself are on current versions with automatic updates where possible.
- [ ] Admin accounts use two-step verification and only people who need access have it.
- [ ] A change to checkout code triggers an alert or review, and a contact at your provider knows how to reach you.
- [ ] Your provider's fraud tools, 3-D Secure and velocity limits are switched on.

Refunds, chargebacks and records

Refunds should go back to the original payment method wherever possible. Do not ask customers to send bank details by email. Chargeback disputes involve sharing order data with the provider and sometimes the card issuer, which is covered by your contract basis. Keep dispute files for as long as a claim can be brought, then delete them.

DO THIS NOW **Action list**

Confirm in your provider's dashboard that you use hosted payment fields. Delete any card numbers from email and spreadsheets. List the scripts on your checkout page and remove the ones you cannot justify. Turn on alerts for theme and code changes.

PART III · PAYMENTS, FULFILMENT AND RETURNS

CHAPTER

07

Suppliers, Couriers and Third Parties

The contracts, transfers and checks that stand behind every tool and service in your shop.

IN THIS CHAPTER

- How to tell a processor from an independent controller
- What a data processing agreement must cover
- Dropshipping, marketplaces and fulfilment partners
- Transfers outside the European Economic Area

A shop is a chain of suppliers. Platform, apps, email, helpdesk, warehouse, courier, accountant, ad agency. Every link holds customer data on your behalf, and the strongest security in the world is lost if the weakest supplier leaks it. Under the GDPR you remain responsible for choosing suppliers carefully and for papering the relationship.

Processor or independent controller?

Typical shop suppliers and their roles

Supplier	Usual role	What you need
Shop platform and hosting	Processor	Data processing agreement (DPA)
Email marketing tool	Processor	DPA, and check where data is stored
Helpdesk and chat tool	Processor	DPA, retention settings
Accountant and bookkeeping software	Processor (or controller for its own duties)	DPA or engagement terms
Payment provider	Processor and independent controller	Provider terms, privacy notice mention
Courier and postal service	Usually independent controller	Mention in notice; share minimum data
Advertising platforms	Often joint or independent controller	Consent for pixels; read the controller terms
Marketing agency or freelancer	Processor	DPA and access controls

What a data processing agreement covers

Article 28(3) lists what a contract with a processor must contain. Most reputable suppliers publish a standard DPA that you accept online. You do not have to negotiate it, but you must read it. Look for these points:

1. The supplier processes data only on your documented instructions.
2. Staff with access are bound by confidentiality.
3. Security measures are described and appropriate (Art. 32).
4. Sub-processors need your authorisation or notice, and are bound by the same duties.
5. The supplier helps you respond to customer rights requests.
6. The supplier tells you about a data breach without undue delay.

7 Data is deleted or returned at the end of the service.
8 You may request information to verify compliance.

FOUNDER TIP Create a supplier register

List every supplier, what data they hold, their role, whether you have a signed or accepted DPA, where data is stored and when you last reviewed them. The Bonus toolkit has a ready sheet. When a breach happens, this register tells you instantly who might be affected.

Fulfilment, dropshipping and marketplaces

If a warehouse, fulfilment centre or dropshipping supplier ships your orders, you hand them your customers' names and addresses. They need that data to fulfil the order, so give them only that. Do not send the full customer record, purchase history or marketing status.

If you sell on a marketplace, the platform is usually a controller of the customer data for its own purposes and may be a joint controller with you for some. Customer data you receive through a marketplace is typically for fulfilment only. Using it to build your own marketing list without a basis can breach both the GDPR and the marketplace's rules.

01
TOO MUCH SHARED
A dropshipper receives the full customer export instead of one name and address per order.

02
NO CONTRACT
An app installed from a store with no DPA read, because it was free and took one click.

03
FORGOTTEN ACCESS
A former freelancer or agency still has admin access to the shop and the ad accounts two years later.

Figure 11 Three supplier mistakes

Transfers outside the EEA

Many shop tools are run by companies outside the European Economic Area. Personal data may leave the EEA only if a transfer mechanism applies (Chapter V of the GDPR): an adequacy decision, such as the EU-US Data Privacy Framework for certified US companies, or standard contractual clauses with an assessment of risk. In the Schrems II judgment (C-311/18, 2020) the Court of Justice made clear that you cannot ignore the destination country's laws. For most small shops the practical steps are modest:

- Check where each supplier stores and accesses data, and whether it offers EU hosting.

- Confirm that US suppliers are certified under the Data Privacy Framework or offer standard contractual clauses.
- Mention transfers and safeguards in your privacy notice.
- Watch for changes: the Framework has been challenged in court, and the status can change.

Offboarding

Remove access on the day a supplier or freelancer stops working for you. Ask for deletion of your customer data and written confirmation. Cancel unused apps, because forgotten apps often keep access to the shop's data indefinitely.

> **DO THIS NOW** **Action list**
>
> Build the supplier register. For each supplier, find or save the DPA. Remove access for anyone no longer working with you. Replace one unnecessary full-data export with a minimal data feed this month.



PART III · PAYMENTS, FULFILMENT AND RETURNS

CHAPTER

08

Returns and Customer Information

Returns forms, photos, refunds and the support inbox: where shops quietly collect the most data they do not need.

IN THIS CHAPTER

- What a return process really needs to collect
- How to handle photos, ID requests and bank details
- Keeping the support inbox and chat under control
- How long to keep returns and complaint records

Returns are where customers are most irritated and where shops are least careful. An exhausted support agent asks for a photo, an ID, a bank account number and a long explanation. It all lands in a shared inbox that nobody ever cleans.

Know your rights and duties

EU consumer law gives online buyers a 14-day right to withdraw from most distance contracts (Directive 2011/83/EU). You must refund within 14 days of being informed of the decision, and may wait until the goods are back or proof of posting is shown. These obligations require you to handle certain data, but they do not require everything customers are often asked to provide.

Collect the minimum

What a return needs

Information	Needed?	Better practice
Order number and name	Yes	Look up the order yourself instead of asking for everything again.
Items and reason	Yes, briefly	Offer a dropdown. Free text invites sensitive details.
Photos of damage	Only for damage claims	Ask for photos of the item, not of the customer or the home.
Proof of identity	Almost never	Use the order email as verification.
Bank account details	Only if the original method cannot be refunded	Use a secure form, never email.
Health or personal reasons	No	Do not ask. If volunteered, do not store it.

WATCH OUT **Be careful with sensitive details**

A return reason such as "the medication packaging was damaged", "does not fit after surgery" or "sent to the wrong religious centre" may reveal health or belief, which is special category data under Article 9. You usually have no basis to keep it. Avoid free-text boxes for the reason, and train staff to delete or redact sensitive details volunteered by customers.

The support inbox is a database

A shared mailbox filling with names, addresses, phone numbers, order histories and attachments is a database of customer data, with no retention rules and a lot of people with access. Give it the same discipline as the rest of your shop.

SUPPORT AND RETURNS HYGIENE

- [ ] Only people who handle support have access, each with their own login and two-step verification.
- [ ] Templates ask for the order number rather than for personal details.
- [ ] Customers are told not to send card numbers, ID documents or passwords by email or chat.
- [ ] Attachments with sensitive content are deleted once the case is closed.
- [ ] Closed cases are deleted or archived on a schedule, for example 12 months after closing.
- [ ] Chat and call recordings are announced, limited and reviewed periodically.

REAL-WORLD SCENARIO **Real-world lesson: the recorded card numbers**

The French authority CNIL fined the online retailer Spartoo EUR 250,000 in 2020. Among the failings it identified were keeping customer data for longer than necessary and recording customer-service phone calls in a way that captured bank card details. Both are problems that a small shop can have in miniature: a call recording tool left on, or a helpdesk that stores whatever customers paste in.

Reviews, ratings and disputes

Customer reviews are personal data. Publish a name only if the customer agrees or if a first name and initial is enough. When a customer asks for a review to be removed, consider the request carefully. You may keep records of genuine disputes for as long as a legal claim could arise, but not necessarily display them.

Returns data in practice



Figure 12 A tidy returns flow

Many of your customers will never ask about their data. A few will, usually after a return goes badly. Making the process short and clean protects you in both situations.

DO THIS NOW **Action list**

Rewrite your return form so that the reason is a dropdown. Delete card numbers and ID documents from the support inbox. Add a rule to delete closed cases after a set time. Brief everyone who answers customers on what not to ask for.

PART IV · SECURITY FOR SHOPS

CHAPTER

09

The Shop Security Baseline

Twelve practical controls that protect customer data, and what Article 32 expects of a small shop.

IN THIS CHAPTER

- What "appropriate security" means for a small shop
- The twelve controls that stop most attacks
- How to manage admin access, plugins and backups
- Why staff habits matter more than software

Article 32 of the GDPR requires "appropriate technical and organisational measures" to protect personal data, taking into account the risk, the cost and the state of the art. It does not prescribe a product list. For a small shop, appropriate means a short set of well-chosen controls that you actually keep up.

Six controls for access and people

01
TWO-STEP LOGIN
On the platform admin, email, payment dashboard, domain registrar, ad accounts and accounting. Prefer an authenticator app or security key over text messages.

02
UNIQUE PASSWORDS
A password manager for the team. No shared passwords in chats or spreadsheets.

03
LEAST ACCESS
Each person and each app gets only the permissions they need. Review the list every quarter.

04
BACKUPS
Automated, stored separately from the shop and tested by restoring. An untested backup is a hope, not a backup.

05
EMAIL PROTECTION
SPF, DKIM and DMARC set up for your domain so criminals cannot easily spoof you.

06
STAFF AWARENESS
A short yearly briefing on phishing, fake support calls and fake invoices, and a no-blame way to report mistakes.

Figure 13 Protecting accounts, access and staff

Six controls for the shop itself

01
UPDATES
Platform, theme and plugins on current versions, with automatic updates where safe. Remove what you do not use.

02
HTTPS AND HEADERS
Encrypted connections everywhere. Security headers and a content security policy if your platform supports them.

03
FIREWALL AND BOT CONTROL
A web application firewall or bot protection to slow credential stuffing, scraping and fake orders.

04
SCRIPT CONTROL
A list of every third-party script, especially on login and checkout pages, with an alert on changes.

05
DEVICE HYGIENE
Laptops and phones that touch the shop use disk encryption, screen locks and current updates.

06
LOGGING
Admin logins and changes are logged and kept long enough to investigate a problem.

Figure 14 Protecting the shop and its systems

Where to start if you do nothing else

If twelve is too many, do these four first. They address the most common routes into small shops.

1. Turn on two-step login for every account that can change the shop, send email or move money.
2. Update the platform, theme and plugins, and delete the ones you do not use.
3. Switch on automatic, off-site backups and test one restore.
4. Remove admin access for everyone who no longer needs it.

Your platform and its apps

On a hosted platform, the provider secures the infrastructure, but you control accounts, apps and settings. On a self-hosted shop, you carry all of it. Either way, apps and plugins are the weakest point, because each is code from someone else running inside your shop with access to your data. Prefer well-maintained, widely used extensions. Remove those that have not been updated for a long time. Treat every new plugin as a new supplier: what data does it see, where does it send it and what happens if the developer disappears?

People are part of the system

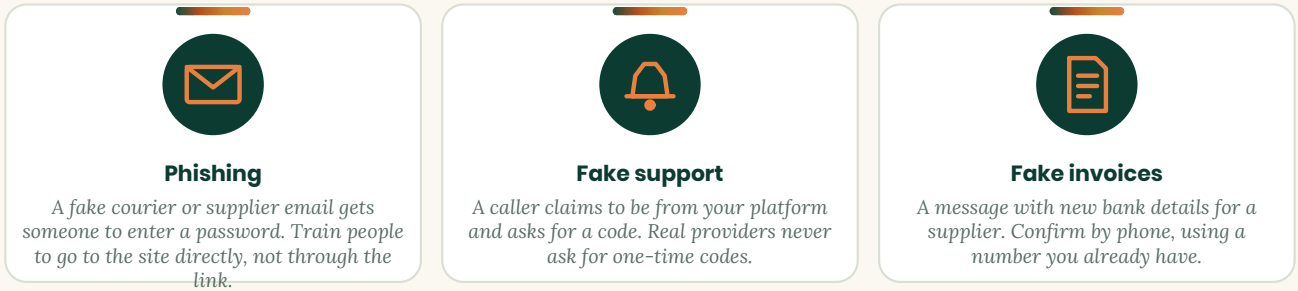


Figure 15 Where staff habits matter most

GOOD PRACTICE **The proportionality principle**

Security measures must be appropriate to the risk. A shop with 200 customers does not need a 24-hour security operations centre. A shop that holds 200,000 customers' addresses and order histories does need more, such as external testing and monitoring. Write down why your measures are proportionate. That note is evidence of accountability.

Document it

Security is as much about showing your reasoning as buying tools. A one-page security statement should list what the shop protects, the main risks, the controls from this chapter and the date of your last review. If an authority or customer ever asks how you protect data, this page is your answer.

DO THIS NOW **Action list**

Choose the four starter steps and finish them this week. Put the other eight controls on a calendar. Write the one-page security statement and date it. Review it every six months.

PART IV · SECURITY FOR SHOPS

CHAPTER

10

How Online Shops Get Attacked

Six attacks that hit small e-commerce businesses, how to spot them and what stops them.

IN THIS CHAPTER

- The six attacks most likely to hit a small shop
- Warning signs for each one
- How to rank risks by likelihood and impact
- Which controls break which attack

Criminals choose targets the way shoppers choose bargains: by effort and reward. Small shops are attractive not because they are interesting, but because they are often easy. Knowing the six main attacks makes the baseline in Chapter 9 feel less abstract.

The six attacks

01
CREDENTIAL STUFFING
Bots try millions of leaked email and password pairs on your login. Successful logins give attackers saved addresses, order histories and sometimes stored credit.

02
CARD SKIMMING
Malicious script on the checkout page copies payment details as customers type. Often arrives through a plugin or third-party script.

03
CARD TESTING
Bots run small purchases with stolen card numbers to find which ones work. You see a flood of tiny failed orders and rising payment fees.

04
ADMIN TAKEOVER
A phished or reused password gives access to the shop admin, where the attacker exports customers or changes bank details.

05
RANSOMWARE AND DATA THEFT
Malware on an office computer or a server encrypts files and copies customer data, then demands payment.

06
SUPPLIER BREACH
An app, agency or hosting provider is compromised and your customer data goes with it.

Figure 16 The usual suspects in e-commerce

Warning signs

What to watch for

Sign	Possible cause
Spike in failed logins from many addresses	Credential stuffing
Many tiny orders with declined cards	Card testing
Customers report fraud after buying from you	Skimming or a leaked order database
Unknown admin users or changed email settings	Admin takeover
New files or scripts in the theme, or an unexpected payment form	Skimming
Customers receive messages from "you" that you never sent	Account or email compromise
Provider or card brand contacts you about suspicious activity	Possible breach, act at once

Rank the risks

You cannot fix everything on day one. A simple matrix helps you choose what to do first by combining how likely an attack is with how much damage it would do to customers. Position yours honestly and start in the top-right corner.

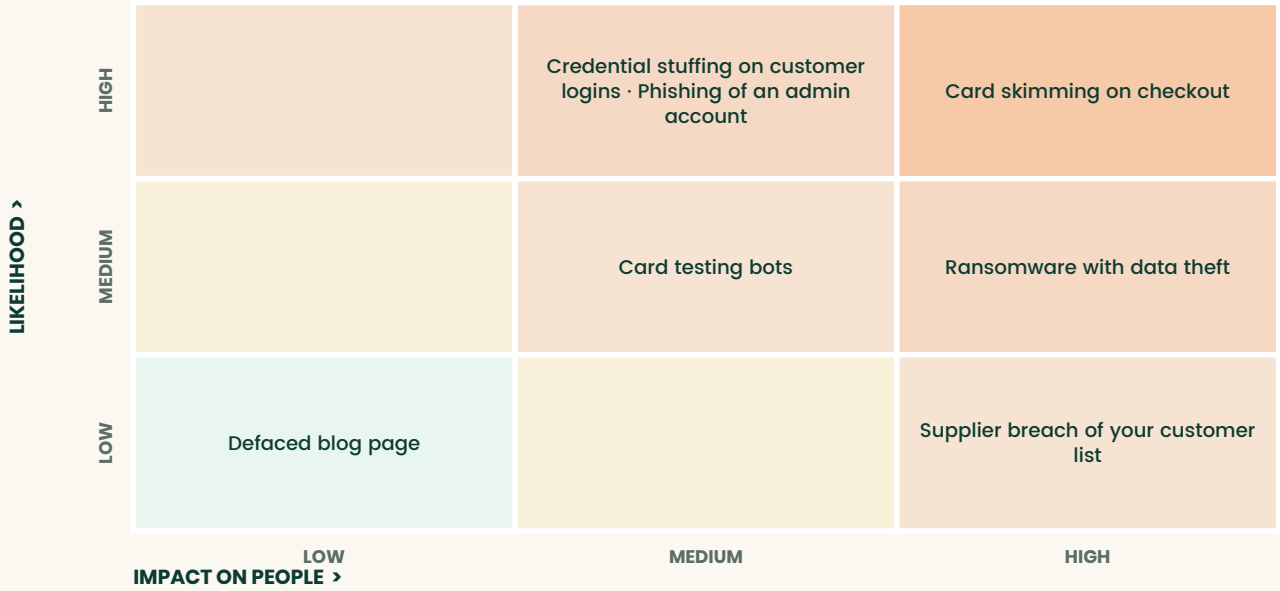


Figure 17 Likelihood of an attack against impact on customers

What stops what

Controls mapped to attacks

Attack	Strongest controls
Credential stuffing	Bot protection, login rate limits, two-step or passkey login, alerts
Card skimming	Hosted payment fields, script inventory, updates, change alerts
Card testing	Bot protection, CAPTCHA at checkout, provider fraud rules, order limits
Admin takeover	Two-step login, unique passwords, least access, phishing training
Ransomware	Updates, backups, device security, least access, staff awareness
Supplier breach	Supplier register, DPAs, data minimisation, access review

REAL-WORLD SCENARIO **Real-world scenario: the plugin that was never updated**

A homeware shop installs a popular reviews plugin and never opens it again. A year later a vulnerability is published, and automated scanners find the shop within days. Attackers add a script to the checkout page. For six weeks, customers' card details are copied. The shop learns of it only when a payment provider calls about a pattern of fraud. The shop must now notify the authority, tell hundreds of customers and pay for a forensic investigation. An automatic update, or deleting the unused plugin, would have cost nothing.

Report and learn

If you are attacked and personal data may be involved, the next chapter tells you what to do. If you are attacked and nothing was taken, you should still write it down. A short log of attempted attacks shows an authority that you monitor, and it points to what to fix.

DO THIS NOW **Action list**

Plot your own shop on the likelihood-impact matrix. Choose the top two risks. Apply the first control in the "what stops what" table to each this month.

PART IV · SECURITY FOR SHOPS

CHAPTER

11

If Something Goes Wrong

Breach basics for shop owners: the 72-hour clock, who to tell and what to say to customers.

IN THIS CHAPTER

- What counts as a personal data breach in a shop
- The 72-hour rule and the high-risk test
- What to tell customers and in what words
- The records you must keep

Sooner or later, every shop has an incident. A laptop is stolen, a spreadsheet goes to the wrong person, a plugin is compromised, a supplier is hacked. What matters is how quickly and calmly you respond.

What is a personal data breach?

A personal data breach is a security incident that leads to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data (Art. 4(12)). It is not only hacking. Sending an order export to the wrong email address is a breach. So is losing an unencrypted phone, or ransomware that locks your customer database even if nothing is copied.

The three decisions

1	**Is personal data involved?**	**YES** Continue to the next question	**NO** Not a GDPR breach. Keep your incident notes.
2	**Is the breach unlikely to result in a risk to people?**	**YES** Record it internally (Art. 33(5)) and note your reasoning. No notification.	**NO** Notify the supervisory authority within 72 hours (Art. 33).
3	**Is the breach likely to result in a high risk to people?**	**YES** Also tell the affected customers without undue delay (Art. 34).	**NO** Authority only. Keep the reasoning.

Figure 18 Which duties apply to your breach?

GDPR IN PLAIN ENGLISH **The clock starts at awareness**

The 72 hours run from the moment you become aware that personal data has been compromised, not from the start of the attack. If you cannot give full details, you can notify in phases. When in doubt, lean towards notifying, because the cost of failing to notify is usually higher than the cost of an unnecessary report.

Which breaches usually reach customers?

High risk is likely when the data could lead to fraud, identity theft, financial loss or other serious harm. Card details, passwords, identity documents, and combined name-address-phone-order data are typical examples. A leaked newsletter list with only email addresses is usually lower risk, but a list that reveals sensitive purchases is not.

Examples from a shop

Incident	Likely level
Unencrypted laptop with a customer export is stolen	Notify the authority; tell customers if the data is useful to fraudsters
Checkout skimmer copied card details for six weeks	Notify the authority and tell customers, and contact your payment provider
Email to 50 customers shows all addresses in the To field	Record it; notify only if the risk is more than minimal
Credential stuffing accessed 30 customer accounts	Notify the authority; tell affected customers and force a password reset
Newsletter tool breach leaks emails only	Assess the risk; supplier must tell you, then decide

The first day

Hour 0 — **Notice**
Someone sees a fraud report, an unknown admin user or an odd page. Open a written log with the time.

Hours 1 to 4 — **Contain**
Change admin passwords, revoke access, disable the suspect plugin, call your platform and payment provider.

Hours 4 to 12 — **Assess**
What data, whose, how many, still happening? Preserve logs and screenshots.

Hours 12 to 24 — **Decide**
Risk to customers? Notify the authority? Draft the customer message.

Within 72 hours — **Notify**
Submit the authority report, even if incomplete, and update it later.

Figure 19 A shop incident, hour by hour

> FOUNDER TIP **The longer playbook**
>
> This chapter gives a shop owner's summary. If you want the full hour-by-hour response, with a contact card, an evidence log and notice templates, see the companion book *Your Business Has Been Hacked. Now What?* by the same author.

What to tell customers

When Article 34 applies, the message must be in clear and plain language and should include what happened, the likely consequences, what you have done, what customers can do to protect themselves and who to contact. Send it directly by email or letter, not only as a notice on the website.

Customer notice (draft, adapt before use)

```
Subject: Important: a security incident affecting your data at [Shop name]

Dear [first name],

On [date] we discovered that [short, factual description]. We acted at once to stop it.

What data was involved: [list, e.g. name, delivery address, email, order history. Say clearly if
 payment card details were NOT involved.]

What this may mean for you: [e.g. you may receive fake emails that look like they come from us.]

What we have done: [e.g. closed the access, informed the authority, strengthened login security.
]

What you can do: [e.g. change your password here, ignore unexpected links, check your bank state
ments, contact your bank.]

If you have questions, contact [name] at [email] or [phone].

We are sorry this happened.
[Name, role]
```

Keep the breach register

Article 33(5) requires you to document every personal data breach, including those you did not report. A simple table is enough: date, what happened, data and people affected, effects, actions taken, the decision about notification and the reasons. The Bonus toolkit includes a template.

> **DO THIS NOW** **Action list**
>
> Decide today who in your business takes the lead if there is an incident, and who is the backup. Save the phone numbers of your platform support, payment provider and IT help in one place outside the shop. Practise once by walking through the decision tree with a made-up example.

PART V · RIGHTS, RETENTION AND PAPERWORK

CHAPTER

12

Rights, Retention and Documents

Customer requests, how long to keep what, and the handful of documents every shop should have.

IN THIS CHAPTER

- How to answer access, erasure and objection requests
- A realistic retention schedule for a shop
- The documents an authority will ask for first
- When a data protection impact assessment is needed

Eventually a customer will write: "Please send me all the data you hold about me", or "Delete my account and everything else." If you have done the work in Chapters 2 to 9, this is a half-hour job. If you have not, it can be a week of searching through inboxes.

Customer rights in a shop



Figure 20 The rights you will meet most often

Other rights include correction (Art. 16), restriction (Art. 18) and portability (Art. 20), which applies to data provided by the customer where you process it by consent or contract. You have **one month** to respond, extendable by up to two further months for complex or numerous requests (Art. 12(3)). Responses are free of charge unless a request is manifestly unfounded or excessive.

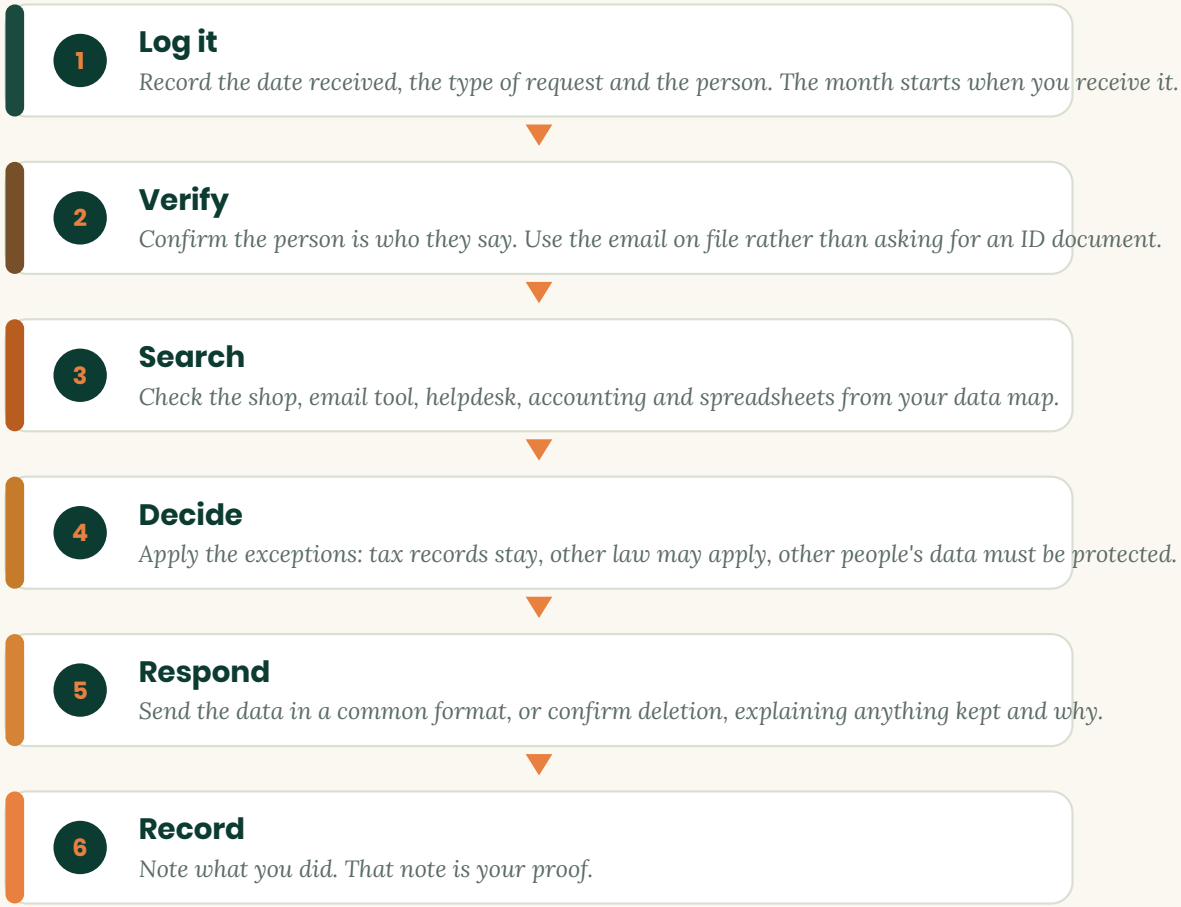


Figure 21 Handling a request in six steps

WATCH OUT **Do not send data to the wrong person**

Fake access requests are a known way to steal data. Never send a customer's data to an email address that is not the one on file without further checks. A mistake here is itself a breach.

Retention: keep it only as long as needed

Storage limitation means setting a period for each type of data and deleting at the end. Periods depend on your purpose, your sector and national law, particularly tax and accounting rules, which commonly require invoices to be kept for several years. The table is a starting point for discussion, not legal advice. Replace it with the periods that apply to you.

An illustrative retention schedule (check national rules)

Data	Typical approach
Invoices and accounting records	As required by tax and accounting law, often six to ten years. Restrict access.
Order details beyond the invoice	Delete or anonymise after the withdrawal and warranty periods end.
Customer account	Until the customer closes it, or after a defined period of inactivity (for example two to three years) with a prior warning.
Marketing consent and list	Until withdrawal. Keep a minimal suppression record.
Abandoned baskets and unconfirmed sign-ups	A few weeks.
Support and returns cases	About 12 months after closing, unless a dispute is open.
Payment dispute files	Until the claim period ends.
Analytics and logs	Shortest period that serves the purpose, often 12 to 14 months for analytics, shorter for access logs.

FOUNDER TIP **Automate deletion**

A schedule that depends on remembering to delete will fail. Use the platform's retention settings, email tool rules and calendar reminders for the rest. Once a quarter, spot-check that the deletions happened.

The documents an authority asks for first

YOUR PRIVACY PAPERWORK

- [ ] Privacy notice on the website, in plain language, covering purposes, bases, recipients, transfers, retention and rights (Arts. 13 and 14).
- [ ] Cookie notice and a consent record for non-essential trackers.
- [ ] Record of processing, in the form of your data map (Art. 30).
- [ ] Supplier register with data processing agreements (Art. 28).
- [ ] Security statement describing your baseline (Art. 32).
- [ ] Breach register and a short incident plan (Art. 33(5)).
- [ ] Retention schedule with someone responsible for it.
- [ ] A short log of customer requests and how they were handled.

When you need an impact assessment

A data protection impact assessment (Art. 35) is required when processing is likely to result in a high risk to people, for example large-scale profiling, systematic monitoring or large volumes of sensitive data. A typical small shop selling ordinary goods rarely needs one. A shop that builds detailed behavioural profiles, uses automated decisions with significant effects or sells products revealing health information at scale should consider one. Your national authority publishes a list of cases where an assessment is required.

DO THIS NOW **Action list**

Write a one-page procedure for customer requests and test it on yourself. Fill in the retention schedule. Check that all eight documents exist, and date them.

PART V · RIGHTS, RETENTION AND PAPERWORK

CHAPTER

13

Your 30-Day Privacy-Safe Shop Plan

One week at a time: the order in which to do everything in this book, and a scorecard to measure progress.

IN THIS CHAPTER

- A four-week plan you can run alongside your normal work
- How to score your shop today
- What to review every quarter and every year
- A closing checklist for the privacy-safe shop

You have read the chapters. Now turn them into a month. The plan below is deliberately modest: about three hours a week for a small shop. Skipping to the high-impact items first protects customers fastest.

Four weeks

Week 1

Know and lock

Build the data map and supplier register. Switch on two-step login everywhere. Update the platform and delete unused plugins. Test a backup restore.

Week 2

Checkout and cookies

Remove unneeded checkout fields. Turn on guest checkout. Check the payment page uses hosted fields and list its scripts. Run the cookie test and fix the banner.

Week 3

Marketing and suppliers

Clean the email list and unticked sign-up boxes. Check unsubscribe. Find or sign a DPA for every supplier. Remove old access.

Week 4

Rights and response

Write the request procedure and the retention schedule. Prepare the incident contact card. Update the privacy notice. Date the security statement.

Figure 22 The 30-day plan

Score your shop

Give yourself one point for each statement that is true today. This is a self-check, not an audit, and a way to see progress over time.

STATEMENT	YOUR SCORE	OUT OF
I know every system that holds customer data (data map exists)		1
Guest checkout is available and checkout asks only for what is needed		1
Marketing boxes are unticked and consent is recorded with date and wording		1
Declining cookies really stops advertising and analytics tags		1
Card details are entered only on the provider's hosted fields		1
Every supplier has a contract or accepted DPA and is in the register		1
Two-step login protects every admin, email and payment account		1
Plugins and platform are current and backups are tested		1
Returns and support do not collect or keep unnecessary personal data		1
A retention schedule exists and deletion is automated where possible		1
Customer requests have a written procedure and a log		1
An incident lead, contact card and breach register are ready		1
TOTAL SHOP SCORE		**12**

0 to 4	5 to 8	9 to 11	12
Exposed	**Developing**	**Solid**	**Privacy-safe**
Several basics are missing. Start with the Week 1 list and do not add new tools until it is done.	The foundations exist. Close the gaps in checkout, cookies and suppliers.	You are doing better than most. Keep reviewing and fix what remains.	Keep it that way with the quarterly and annual rhythm below.

Figure 23 Reading your score

The review rhythm

01
EVERY QUARTER

Review admin and supplier access. Spot-check deletions. Test that an unsubscribe and a cookie rejection work. Check for plugin updates.

02
EVERY YEAR

Update the data map and supplier register. Re-run the cookie scan. Review retention periods and the privacy notice. Test a restore. Refresh staff awareness.

03
WHEN YOU ADD A TOOL

Ask: why, who else sees it, when deleted? Check the DPA and the data location. Update the map.

04
WHEN LAW OR GUIDANCE CHANGES

Read your authority's updates. Rules on cookies, consent and data transfers are still evolving across the EU, including reform proposals, so check before relying on this book for a decision.

Figure 24 Keep it current

A closing thought

Privacy and security are sometimes sold as costs. In a shop, they are closer to craftsmanship: the neat packaging of your customers' trust. People will forgive a late parcel. They rarely forgive a leaked address or an unwanted message after they said stop.

GOOD PRACTICE **Your pledge**

We collect only what we need. We tell people what we do. We choose suppliers carefully. We protect what we hold. We delete what we no longer need. We act quickly when something goes wrong. Print it, pin it up and read it before the next campaign.

BONUS

Privacy-Safe Shop Toolkit

Data map, supplier register, tag audit, retention schedule, request log, breach register and a contact card. Fill them in on screen or print them.

IN THIS CHAPTER

- A data map and a supplier register
- A tag and cookie audit sheet
- A retention schedule and a customer request log
- An incident contact card and a breach register

WATCH OUT **How to use the toolkit**

The tables have fillable fields in the PDF and ruled boxes in print. Complete them once, then keep them up to date. These are educational templates, not legal advice: adapt them to your business and to the rules in your country.

DATA MAP: WHAT WE COLLECT AND WHY

Purpose	Data	Source	Lawful basis	Shared with	Keep for
e.g. Fulfil orders	*Name, address, items*	*Checkout*	*Contract*	*Courier*	*Until delivered, invoice per tax law*

SUPPLIER REGISTER

Supplier	Service	Data held	Role	DPA in place?	Data location	Last review
e.g. Email tool	*Newsletter*	*Names, emails*	*Processor*	*Yes, accepted online*	*EU*	*Mar 2026*

TAG AND COOKIE AUDIT

Tag or cookie	Purpose	Category	Fires before consent?	Keep or remove	Owner
e.g. Ad pixel	*Retargeting*	*Advertising*	*No, after accept*	*Keep*	*Marketing lead*

RETENTION SCHEDULE

Data	Retention period	Reason	How it is deleted	Responsible	Next check
e.g. Closed support cases	*12 months*	*Handle complaints*	*Helpdesk rule*	*Support lead*	*Quarterly*

CUSTOMER REQUEST LOG

Date received	Type of request	Identity checked	Action taken	Date answered	Notes
e.g. 2 Apr	*Access*	*Yes, via account email*	*Export sent*	*14 Apr*	*Included order history*

WORKSHEET

Incident contact card

Fill this in now. Print it and keep copies outside your systems.

Incident lead (name, mobile)

Deputy (name, mobile)

Technical help or IT provider (name, 24-hour number)

Shop platform support (number and account ID)

Payment provider fraud and security contact

Hosting and domain provider support

Privacy lead or DPO (name, mobile)

Lawyer or adviser (name, number)

Cyber insurer (policy number and hotline)

Supervisory authority breach form (web address)

PERSONAL DATA BREACH REGISTER (ART. 33(5))

Date aware	Facts	Data and people affected	Effects	Actions taken	Authority told?	Customers told?	Reasoning
e.g. 3 May	*Plugin compromised*	*Order data, about 300 customers*	*Fraud risk*	*Removed plugin, reset admin*	*Yes, 4 May*	*Yes, 5 May*	*High risk to customers*

Shop security quick check

TEN-MINUTE SECURITY CHECK

- ☐ Two-step login is on for platform, email, payment, domain and ad accounts.
- ☐ All plugins and themes are current and unused ones are deleted.
- ☐ A backup ran in the last 24 hours and was restored successfully in the last six months.
- ☐ Checkout loads only the scripts you can name.
- ☐ Former staff, freelancers and agencies no longer have access.
- ☐ Declining cookies stops advertising tags in a private browser window.
- ☐ No card numbers or ID documents sit in email, chat or spreadsheets.
- ☐ The unsubscribe link works in one click.
- ☐ The incident contact card is filled in and printed.
- ☐ The privacy notice matches what the shop does today.

Plain-English Glossary

The terms you will meet on the way, in alphabetical order.

Abandoned cart	A basket a visitor filled but did not buy. Reminder emails about it may need consent, depending on national rules.
Adequacy decision	A formal EU finding that a non-EU country or framework gives personal data essentially equivalent protection.
Controller	The organisation that decides why and how personal data is processed. For your customers' data, that is your shop.
Consent	A free, specific, informed and unambiguous choice, given by a clear action, that the person can withdraw as easily as they gave it.
Credential stuffing	Automated login attempts using email and password pairs leaked from other sites.
Data map	A one-page overview of what personal data you hold, why, where it goes and how long you keep it.
Data subject	The person the personal data is about, such as a customer or newsletter subscriber.
DPA	Data processing agreement: the contract with a processor required by Article 28.
DPIA	Data protection impact assessment: a structured risk review required for high-risk processing (Art. 35).
Double opt-in	A sign-up that is confirmed through a link sent to the email address, giving strong proof of consent.
Guest checkout	Buying without creating an account.
Joint controllers	Two or more parties that decide together why and how data is processed.
Legitimate interests	A lawful basis that needs a documented balance between your interest and the person's rights.
Magecart-style skimming	Malicious script on a checkout page that copies payment details as customers type.
PCI DSS	The card brands' security standard for businesses that handle card payments.
Personal data breach	A security incident leading to destruction, loss, alteration, unauthorised disclosure of or access to personal data.

Pixel	A small piece of code that sends information about a visitor's behaviour to another company, often for advertising.
Processor	A supplier that handles personal data on the controller's instructions.
PSD2 / SCA	The Payment Services Directive and its strong customer authentication rule for online card payments.
Record of processing	The written overview of processing activities required by Article 30.
Retention schedule	A list of how long each type of data is kept and how it is deleted.
Soft opt-in	A narrow exception that allows email marketing of similar products to existing customers, with an easy way to refuse.
Supervisory authority	The national data protection regulator, such as the CNIL in France.
Suppression list	A list of people who must not be contacted, kept so that they are not re-added.
Tokenisation	Replacing a card number with a meaningless token so that the shop never holds the real number.
Two-step verification	A second proof of identity, such as an app code or security key, in addition to the password.

Official Sources & Further Reading

Where the legal claims in this book come from, and where to check what applies today.

Always prefer the primary sources below to summaries, including this one. Web addresses change: if a link has moved, search the official site for the title shown. Guidance is updated regularly, so check for the latest version before relying on it.

Primary EU law (EUR-Lex)

- **General Data Protection Regulation (GDPR)**, Regulation (EU) 2016/679. Notably Arts. 4, 5, 6, 7, 8, 12 to 22, 25, 28, 30, 32, 33, 34, 35, 44 to 49 and 83. eur-lex.europa.eu/eli/reg/2016/679/oj
- **ePrivacy Directive**, Directive 2002/58/EC, Art. 5(3) (storing or accessing information on devices) and Art. 13 (unsolicited communications), as implemented in each member state.
- **Consumer Rights Directive**, Directive 2011/83/EU, on the 14-day right of withdrawal for distance contracts and refund timing.
- **Payment Services Directive (PSD2)**, Directive (EU) 2015/2366, on strong customer authentication.
- **NIS2 Directive**, Directive (EU) 2022/2555. Applies through national laws and mainly to larger or specified sectors: check yours.

Court decisions

- **Planet49**, Court of Justice, Case C-673/17 (1 October 2019): active consent for cookies; pre-ticked boxes are not valid.
- **Fashion ID**, Court of Justice, Case C-40/17 (29 July 2019): joint controllership for an embedded social plugin.
- **Schrems II**, Court of Justice, Case C-311/18 (16 July 2020): international transfers and standard contractual clauses.
- **SCHUFA**, Court of Justice, Case C-634/21 (7 December 2023): credit scoring as an automated decision.

Regulators and guidance

- **European Data Protection Board (EDPB)**: guidelines on consent, controllers and processors, personal data breach notification, and the report of the cookie banner taskforce. edpb.europa.eu
- **Your national data protection authority**: guidance on cookies, direct marketing and breach reporting. Find yours on the EDPB website.
- **CNIL (France)**, decision of 1 September 2025 against Shein's Irish subsidiary (EUR 150 million, announced 3 September 2025), and the 2020 sanction against Spartoo (EUR 250,000): cnil.fr
- **UK Information Commissioner's Office**, penalty notices against British Airways (October 2020, GBP 20 million) and Ticketmaster UK (November 2020, GBP 1.25 million): ico.org.uk. These were issued under the UK regime, which mirrors the GDPR.
- **European Commission**, adequacy decision for the EU-US Data Privacy Framework (10 July 2023). Check the current status of legal challenges.
- **PCI Security Standards Council**, PCI DSS v4.0.1 and guidance for small merchants: pcisecuritystandards.org

WATCH OUT **What this book could not verify for you**

Proposals to change EU data protection and cookie rules (the so-called Digital Omnibus) were still proposals when this book was written and must be checked against EUR-Lex and the European Parliament. Retention periods in this book are illustrative, because tax and accounting rules differ by country. Email marketing exceptions and cookie exemptions also vary nationally. The scenarios are fictional. Check each point against the primary source and take advice from a qualified professional before relying on it.

About the Author

Zirlandia Milkovic

Zirlandia Milkovic writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes privacy is not a barrier to ambition but a foundation of trust, and that founders should not need a legal degree to understand the rules that apply to them.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex European rules into simple steps, checklists and templates that busy founders can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Stay in touch

Visit **gdprgard.eu** for free tools, articles and updates, including notes on changes to the rules covered in this book. If this guide helped you, an honest review where you bought it helps other shop owners find it.

> AI & PRIVACY **Note to the reader**
>
> This book is educational and not legal advice. Laws and guidance change, so check the sources in the previous section and consult a qualified professional about your own circumstances.


Collect less.
Protect more.
Earn the trust.
ZIRLANDIA MILKOVIC